Threat evolution in Q2 2017

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive Summary: Threats to the Financial Sector, Global 4
Executive Summary: Threats to Financial Sector in Russia and the CIS 6
Executive Summary: Threats to the Government sector 8
Forecasts for Q3 2017 9
Threats to the Financial Sector, Global 10
Targeted attacks 11
Banking threats for PC and Android 17
Attacks on ATM and POS terminals 25
Data leakage 26
Threats to the Financial Sector in Russia and the CIS 27
Targeted attacks 28
Banking Trojans for PC and Android 30
Attacks on ATMs 32
Data leakage 32
Threats for the Governments 33
APT 34
Hacktivism 36
Deface attacks: Additional Statistics 37
Data leakage 40

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on the USA, Canada, Europe, Russia and Australia. This document also provides a comprehensive description of threats to governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring the most secretive underground hacker forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

The second quarter of 2017 has been very eventful for the information security industry. The WannaCry and Petya ransomware outbreaks have gathered a lot of attention from the media; a Russian hacker Pyotr Levashov (Severa), who is included in the world's Top 10 Worst Spammers list, was arrested; Group-IB specialists revealed technical details of the APT Lazarus group, Shadow Brokers published archives with NSA tools; Cobalt and MoneyTaker groups continue to attack financial organizations.

Executive Summary: Threats to the Financial Sector, Global

Targeted attacks

- The Cobalt hacker group is attacking banks worldwide, currently they are primarily targeting card processing systems. The hackers began to test their own backdoor. Researchers also revealed that they used PetrWrap ransomware (a modified version of Petya malware).
- Group-IB specialists identified 13 successful targeted attacks of the MoneyTaker group (Fin7), some of which may still be undetected by the victims. The group is targeting community banks. In their attacks, criminals compromised corporate networks, in some cases, they accessed confidential documents related to SWIFT, card processing systems, ATM control software and other highly sensitive information about VIP clients of banks. Their key points of compromise are spear-phishing emails and hacked networks of providers that render services to targeted financial organizations.
- Group-IB specialists uncovered technical details of attacks by North Korean hackers Lazarus, who penetrated bank networks. Currently the group is targeting banks. Previously, they had compromised websites of financial regulators in several countries whose visitors they planned to attack: The Polish Financial Supervision Authority, the National Banking and Securities Commission, Mexico, the Banco de la República Oriental del Uruguay (a state-owned bank in Uruguay). Their goal was to gain access to the internal network of the attacked bank, including the SWIFT system. In its arsenal Lazarus has a special tool designed to collect information about SWIFT transactions.
- TA549 is attacking financial institutions in Central Asia, Russia, Belarus, and Mongolia.

Banking threats for PC and Android

Trojans for Android were used to steal money from the accounts of individuals, while PC Trojans were used both for attacks on individuals and companies. All malicious programs outlined in this section are only targeting non-Russian and former CIS countries:

Trojans for Android:

- After the disruption of the Cron criminal group, specialists saw a surge in sales of new Android Trojans on underground forums. That said, all of them are targeting only banks outside the CIS. Examples of such Trojans are Rello, Loki, Red Alert.
- Clients of European, Australian banks, as well as banks in the US are under threat of attacks using the Android Trojans Marcher and Alien bot.

Trojans for PC:

- During the reporting period, Group-IB specialists detected attacks on banks in Europe, the US, Canada and Australia using bank Trojans Trickbot, Gootkit, Tinba, Qadars, Zeus, ZeusVM, Qbot, Citadel, and Atmos.
- In April the Dridex banking Trojan was distributed using a zero-day vulnerability in the algorithm for handling OLE2Link objects in MS Office software, later Microsoft released a respective patch.
- Ramnit activity decreased.
- Group-IB specialists did not detect any activity of the banking Trojan Kronos. That said, its sales on an underground forum also stopped because its developer (VinnyK) was banned.
- A source code of a new remote access Trojan, the RATAttack toolkit that uses the Telegram protocol was made public.

Attacks on ATM and POS terminals

- Europol arrested 27 members of the Black Box group accused of being involved in a series of successful black box attacks against ATMs across Europe, which resulted in more than €45 million in losses.
- Incidents using Blackbox devices for thefts from ATMs were identified in Switzerland, Spain, and Ukraine.
- A new version of the RawPOS Trojan targeting POS terminals was discovered.
- Experts uncovered and analyzed a malicious program designed to steal money from ATMs dubbed ATMitch.
- Cobalt and MoneyTaker (Fin7) purportedly performed attacks on ATMs.
- 31 members of a criminal group that had been involved in thefts using skimmers in Spain and Bulgaria from 2014 to 2017 were detained.

Data leakage

In Q2 2017, the following major data leaks were detected:

- Code-named "HospitalGown," a new vulnerability in mobile applications exposed over 280 million records with personal data.
- InterContinental Hotels Group was infected with an unidentified Trojan designed to access payment card data, which affected more than 1,000 hotels.
- The American retail chain Kmart experienced a point of sale data breach that has affected a number of stores and customers.

Executive Summary: Threats to Financial Sector in Russia and the CIS

Targeted attacks

- Previously, Group-IB experts warned that the Cobalt hacker group could start using ransomware in their attacks to distract attention from the main attack. This forecast came true: the attackers successfully gained access to the bank's corporate network and infected computers with PetrWrap ransomware.
- Group-IB specialists revealed details of the attack on financial institutions in Ukraine using the TELEBOT backdoor, which was controlled through the Telegram Bot API. The malicious program was distributed using phishing emails containing Microsoft Excel documents with malicious macros. Activity of this group is similar to that of the Black Energy group, which was behind various attacks on energy companies in Ukraine.
- A large-scale attack using the Petya ransomware affected financial institutions in Ukraine. This massive infection was purportedly performed by the Telebot group. This hypothesis is based on the malware distribution through servers of the M.E.Doc company; previously the same infection vector had been used by the Telebot group to deliver Win32/Filecoder.AESNI.C ransomware.

Banking Trojans for PC and Android

During the reporting period, Group-IB specialists detected attacks on clients of Russian banks using specific Trojans. The vast majority of Trojans for PC were used to deplete accounts of businesses, while mobile Trojans were used to steal money from the accounts of individuals. In Q2 2017, Group-IB specialists observed activity of the following banking Trojans:

Trojans for PC:

- In Russia, the most active Trojans are RTM, Buhtrap, Ranbyus, and Jupiter.
- A group ProxyAdder that actively attacked banks in Kazakhstan again temporarily suspended their activity. They had terminated their activity earlier, but later they returned.
- Massive infection of Russian banks with Adwind spyware was detected.
- The Buhtrap banking Trojan, whose source codes are publicly available, was used by cyber-criminals to attack funds. The theft amount is estimated at 1-3 million rubles.

Mobile Trojans:

- Mobile Trojans: Asacub, Gugi (Limebot), Honli, Agent.sx, a new version of Limebot dubbed Lipton.
- Criminals again started using the Agent.BID Android Trojan.
- With active support from Group-IB, Russian legal enforcement arrested the Cron gang for that had infected about 1 million Android devices in Russia and planned to start their "international activity" with attacks targeting banks in France.
- Activity of the Tiny.z Trojan (aka Catelites Android Bot, MarsElite Android Bot) decreased.
- We again detected attacks using a rather old Android Trojan FlexNet.

Attacks on ATMs

- The ATMitch malicious program was used to steal money from ATMs of Russian banks; attackers have not been identified.
- Cobalt and MoneyTaker (Fin7) may have performed attacks on ATMs.

Data leakage

During the reporting period, Group-IB specialists detected 13 incidents of malicious insider activity in Russian banks. They continued offering services of confidential bank data sales and remote bank account opening and promoted them on underground platforms.

Executive Summary: Threats to the Government sector

Targeted attacks

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q2 2017 the following active APT campaigns were detected: APT10, Lazarus, APT32, APT3, APT19, PLATINUM, Telebot, and an unknown group attacking think tanks and government organizations in India.

APT10 is targeting service providers in Canada, USA, Norway, Finland, France, Great Britain, Sweden, Switzerland, Brazil, South Africa, India, Thailand, South Korea, Japan, and Australia. Lazarus is attacking infrastructure of banks throughout the world.

APT32 is active in Europe, Vietnam, USA, Philippines, Great Britain, Germany, China, affecting network security companies, banks, retailers, and media. APT19 is attacking law firms and investment companies. The hacking group known as APT3 is believed to be linked to the Chinese government.

Hacktivism

In Q2 2017, hacktivists conducted over 3,800 attacks on more than 4,900 unique online resources. Over 3,100 attacks detected were “page replacement” (Defacement), 500 attacks were DDoS attacks (Denial of Service) and more than 200 incidents of data leakage were detected. In these attacks hacktivists targeted government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Mexico, Brazil, Turkey, Sri Lanka, Venezuela, USA, Peru, Italy, Laos, Nepal, Pakistan.

Data leakage

- In May and June WikiLeaks released documents providing insights into how the CIA was secretly spying on their targets. On May 19 the resource published new documents detailing the Athena project, In early June WikiLeaks published a new portion of documents on an alleged CIA’s "Pandemic" project
- The Shadow Brokers group published archives of the NSA espionage tools that may be used by government-backed groups. They also launched a subscription-based monthly dump of new tools from the NSA and CIA leaks. There are ETERNALBLUE, ESTEEMAUDIT, Eternalchampion, Eternalromance, Eternalsynergy, Doublepulsar, Architouch, SMBtouch and others among them.
- The personal information of more than 198 million American voters were available publicly on the Amazon S3 server. Data was collected during the preparation for the presidential elections by the analytical company Deep Root Analytics (DRA) and two other contractors for the Republican Party.

Forecasts for Q3 2017

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, Australia, Canada:

1) Exploits from the NSA and CIA leaks will be used more actively to conduct targeted attacks. They have been included in the basic penetration testing tools of financially motivated and state-backed hackers.
2) MoneyTaker will continue to focus on small American banks. One of the key methods to escalate privileges in the corporate network is now a vulnerability in the configuration of Microsoft Group Policy Preferences.
3) The Cobalt group will focus on bank processing systems; their attacks will become more complicated due to new tools developed.
4) After the arrest of the Cron group members, we forecast an increase in money thefts using Android Trojans outside Russia. In Q2 we observed a surge in sales of new Android Trojans on underground forums, and all of them are configured to attack banks outside the CIS countries. Accordingly, this will lead to an increase in thefts from bank customers.
5) We predict that large-scale attacks using ransomware will continue, because the recent WannaCry and Petya outbreaks have clearly demonstrated that organizations remain totally vulnerable to this type of cyber- attacks.
6) Shadow Brokers have announced that they are launching a subscription-based monthly dump of new tools from the NSA and CIA leaks. They have created a program with a paid subscription. Depending on the published data, new threats may appear, which will become widespread.
7) After the publication of the source code for a new remote access Trojan, the RATAttack toolkit, the number of similar programs based on this source code will increase.
8) The most dangerous banking Trojans will be Tinba and Dridex.
9) Marcher and Alien bot will attack banks in Europe, Australia, and the USA.

Based on the threats detected, we can forecast the following future incidents in Russia and the CIS:

1) The Cobalt group will continue to send malicious emails, attack corporate IT infrastructure, perform thefts from banks. The hacker group is currently testing a new reconnaissance Trojan on the territory of Russia – this can complicate investigative activity and increase the effectiveness of their future attacks.
2) The MoneyTaker group, along with the start of operations in the US and Hong Kong, will continue attacking Russian financial institutions.
3) To steal money from users of Android devices, hackers will actively employ Limebot and its new version dubbed Lipton, Agent.BID, Agent.sx and Asacub.
4) RTM and Ranbyus Trojans will be used to perform thefts from Windows users.
5) Group-IB specialists expect new attacks using ransomware similar to WannaCry and Petya.

Threats to the Financial Sector, Global

We recommend that you also read about Threats to the Financial Sector in Russia and the CIS, as techniques and tools targeting Russian institutions are often exported after testing.

GROUP-IB

GLOBAL CYBER SECURITY COMPANY

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks from the Cobalt hacker group	Russia, Kazakhstan, Ukraine	CP-1438-17 – CP-1438-25	June 2016

In Q2 2017 researchers detected numerous spear-phishing campaigns from the Cobalt group, primarily targeting banks and payment systems in Russia, as well as financial institutions in Kazakhstan and Ukraine. In addition they sent emails in English, targeting companies outside the CIS. Mailouts were performed acting as the CyberPlat payment system, the mobile operators Beeline, MTS, Megafon, as well as Sberbank, PCI DSS, the Moneta.ru instant payment system, FinCERT, and Qiwi payment system.

Also, cybercriminals sent malicious emails from compromised corporate servers, for example, they leveraged a server belonging to the cash collection service of the Kazakh bank Halyk Bank.

The English-language mailout was performed from the sender secure@pcidss-visa.com; the malicious file was called "PCI DSS roles.doc".

Emails contained documents with exploits for CVE-2017-0199 and CVE-2016-7193 vulnerabilities.

Some of the attacks led to successful thefts.

Researchers also revealed that through one of the attacks criminals successfully obtained access to the bank's corporate network and infected machines with PetrWrap ransomware.

In May, researchers detected that the Cobalt Group was testing a new reconnaissance Trojan on the territory of Russia. This new tool may complicate tracking the criminal group, as well as increase the effectiveness of their future attacks.

APT name	Regions attacked	Related notifications	Operation start
MoneyTaker (Fin7)	USA, Russia, Hong Kong	CP-1559	2016

The MoneyTaker group (aka Fin7) is a Russian-speaking technically sophisticated criminal group that conducts targeted attacks on financial institutions throughout the world. Their main goal is to gain access to critical bank systems such as SWIFT, ATMs, card processing systems, banking software, POS software, as well as to steal confidential documents to commit fraud.

Moneytaker is closely linked to Anunak (Carbanak). One of their distinguishing features is that they usually load their tools into the memory of an infected machine, that's why researchers call their attacks "file-less". With this attack method, it is extremely difficult to detect the infection using antivirus and IDS solutions, because the operation of malicious programs and data transfer are hidden.

Their peak activity was observed in late 2016, when they actively attacked financial companies in Russia, Hong Kong, and the United States. At the time, a number of security companies began to investigate activity of group, which they dubbed Fin7. In Russia, they performed a successful attack via the ARM CBR (Automated Work Station Client of the Russian Central Bank).

In Q2 2017, Group-IB specialists managed to discover the critical infrastructure of Fin7 and identify thirteen successful targeted attacks, some of which may still remain undetected by the victims. In these attacks, criminals

compromised corporate networks and, in some cases, accessed confidential documents related to SWIFT, card processing systems, ATM control software and other highly sensitive information about VIP clients of banks.

Hackers infiltrate corporate networks using spear-phishing emails with malicious files acting as financial organizations or leverage compromised networks of financial institutions' Internet providers.

APT name	Regions attacked	Related notifications
Spear phishing emails with the Adwind remote access tool	Global	CP-1577

On June 13, 2017, spear phishing emails containing the Adwind RAT malware were sent to banks worldwide. Emails were disguised as messages from Western Union.

Adwind (aka AlienSpy, Frutas, Unrecom, Sockrat, JSocket, jRat) is a malicious remote access tool (RAT) designed to provide remote access to the infected machine. A distinctive feature is that it runs on the Java platform. Due to this feature, Adwind can be launched on any operating system - Windows, Linux, OS X, Android.

Its functionality includes keylogging, collecting passwords stored in cache, VPN certificates, authentication data for access to electronic wallets, taking screenshots, recording screen video and sound from the device's microphone or video from the webcam, collecting information about the user device and system, control SMS messages in the event they infect a mobile device that runs on Android.

It is worth reiterating that in addition to Adwind currently the hackers actively use the following malicious remote access tools: NanoCore, njRAT, DarkComet, NetWire, hVNC.

In early May, attackers compromised the mirror server for HandBrake, a popular open-source program for converting video files, and used it to distribute a macOS version of the application that contained a new version of the Proton malware. This program was originally discovered in January 2017 on a Russian hacker forum. With Proton, hackers can obtain root privileges on Mac computers. This fact confirms that remote access tools no longer threaten only Windows users.

In April 2017, a source code of a new remote access Trojan, the RATAttack toolkit that uses the Telegram protocol for communications between the victim's machine and the attacker was made public. We believe that this publication will provoke an increase in the number of malicious programs based on this source code.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
NSA hacking tools published by Shadow Brokers, malware distributed using these tools; WannaCry attack	Global	DL-1552 CP-1556 CP-1558 CP-1561 DL-1567

In April 2017, the Shadow Brokers group published two archives with the NSA tools. They contained a large number of malicious programs and 0day exploits, including ETERNALBLUE (exploit for SMB vulnerability in Windows), ESTEEMAUDIT (exploits the RDP protocol vulnerability in Windows XP and Windows Server 2003), Eternalchampion, Eternalromance, Eternalsynergy, Doublepulsar, Architouch and SMBtouch and others.

These publications have led to 'fatal' consequences. On 12 May, 2017 hackers began to distribute the WannaCry ransomware using an exploit codenamed ETERNALBLUE. This worm spread widely by scanning the network for vulnerable hosts. In less than two hours, the malware had infected major companies in 11 countries: Russia, the

United Kingdom, the United States, China, Spain, Italy, Vietnam, and Taiwan. The virus encrypts files, blocks computers and demands ransom of $300 in bitcoin to recover data access.

Microsoft issued a Security Bulletin MS17-010 with relevant patches for the vulnerability in the SMB protocol. Additionally, the company released a security update which addresses the vulnerability in unsupported operating systems Windows XP and Windows Server 2003 R2.

In addition to WannaCry, EternalBlue was used by another malicious program – to install the cryptocurrency miner Adylkuzz – for distribution. It should be noted that the Adylkuzz campaign significantly predated the WannaCry attack, beginning as early as April 24. Adylkuzz does not have the same impact on compromised computers as ransomware threats which could lead to data loss and wide-scale disruption, because it did not block the infected computer, nor did it demand any ransom.

On the wave of WannaCry's success, a worm called EternalRocks (aka MicroBotMassiveNet/BlueDoom) appeared. The malware utilises seven NSA exploits – EternalBlue, Eternalchampion, Eternalromance, Eternalsynergy, Doublepulsar, Architouch and SMBtouch to infect vulnerable computer systems, while masking itself as WannaCry. According to security specialists, EternalRocks is used to prepare a targeted system for further attacks.

Group-IB specialists believe that the attackers will continue actively employ tools from the NSA and CIA leaks to perform attacks.

On May 30, 2017 hacking group Shadow Brokers informed that they started its monthly service to raise cash in return for more NSA hacking tools. To receive data, it was required to pay a monthly fee of 100 ZEC (Zcash, a virtual currency), which equates to about £20,000. The group promised to provide the subscribers with access to hacker tools in early July. Currently, no details about the contents of the archive are available.

On June 28, 2017 the Shadow Brokers group made a publication on the subscription to the July archive, they doubled the price for its monthly subscription model from 100 ZEC (Zcash) to 200 ZEC. They also announced a VIP service to obtain a more personalized level of service, delivering specific data – vulnerabilities, exploits, companies, persons – upon client's request. The VIP service requires a one-time payment of 400 ZEC.

Large-scale attack using ransomware	Regions attacked	Related notifications
Petya	Global	CP-1581

On June 27, 2017, a new modification of the Petya ransomware was used in a large-scale attack primarily on companies with operations in Ukraine and the Russian Federation. Other organisations were also infected on a global scale.

Users of M.E.Doc, Ukrainian accounting software, are widely considered to be the "patient zero" in the attack. The attackers managed to gain access to the update server of this legitimate software. Using access to this server, attackers pushed a malicious update that was applied automatically without user interaction.

Three M.E. Doc software updates, which were issued in 2017, contained a sophisticated backdoor that was injected by attackers into one of M.E. Doc's legitimate modules. The hackers likely managed to perform this due to access to M.E.Doc's source code. The Petya outbreak happened five days after the backdoored June 22 update.

Once machines were infected, users were faced with messages demanding $300 in Bitcoin for decryption of files. Following this, the malware attempted to spread across the corporate network using the infamous EternalBlue exploit and PsExec.

In the first 2 hours, energy, telecommunications and financial companies were attacked - as a result, at least 80 companies throughout the world were affected:

In Russia: oil companies Rosneft and Bashneft, Evraz, Home Credit Bank, and others.

In Ukraine: Zaporizhiaoblenergo, Dneproenergo, the Dnieper electric power system, Mondelez International, Oschadbank, Mars, Nova Poshta, Nivea, TESA, and other companies, Kiev subway, computer networks of the Cabinet of Ministers and the website of the Ukrainian government, Auchan stores, 3 major Ukrainian telecom operators (Kyivstar, LifeCell, Ukrtelecom), Privatbank, the Boryspil international airport.

Globally: Danish shipping firm Maersk, US pharmaceutical giant Merck and others.

Following this, other organisations around the globe were infected.

Exploit	Regions attacked	Related notifications
0day exploit for a vulnerability in Gmail	Global	CP-1548

On April 13, 2017, an announcement about sales of a 0day exploit for a vulnerability in Gmail was published on an underground forum. According to the seller, this exploit is designed to intercept user's sessions. The attacker sends a message with a link to the victim. In the event the victim clicks the link, the session’s cookies will be sent to the attacker's server. With this data, the criminal will be able to bypass two-factor authentication and access Gmail emails. According to the author, the user can use the account and session on different devices and IP addresses with the same session cookies. The attacker offered it at a price of 35,000 USD.

Later, security researchers reported that Gmail users began receiving emails (including from known contacts) with a fraudulent Google Doc link. When following the link, the victim sees a fake document, which requests access to some functions of the user's account. Victims usually grant a permission, not suspecting that this is a malicious request. This gives attackers the highest level of access to the account, with which they are able to bypass two-factor authentication and receive any information from this email account. As a result, about 1 million users have been affected by the hackers.

Following this, Google experts said they had taken action to protect users against an email impersonating Google Docs and had disabled offending accounts. They also removed the fake pages and provided updates as part of the US search firm's Safe Browsing database. Due to these steps, a 0day exploit for vulnerability in Gmail sold on underground forums no longer poses a threat.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Solar exploit kit	Global	CP-1550

In April security specialists discovered an announcement about the sale of the Solar exploit kit, which includes the following exploits:

CVE-2013-2551 - Internet explorer 6-7-8-9-10
CVE-2014-6332 - Internet explorer 3-4-5-6-7-8-9-10-11 [Godmode]
CVE-2015-2419 - JScript 9 on Internet explorer 10-11
CVE-2016-0189 - JScript & VBscript On internet explorer 9-10-11
CVE-2013-1710 - Firefox 23.0 and before
CVE-2014-1510 - Firefox 28.0 and before
CVE-2014-8636 - Firefox 35.0 and before

CVE-2016-9078 - Firefox 49.0-50.0
CVE-2016-0034 - Silverlight
CVE-2015-5122 - Adobe flash player
CVE-2015-0313 - Adobe flash player
CVE-2015-3105 - Adobe flash player
CVE-2015-8651 - Adobe flash player
CVE-2015-7645 - Adobe flash player

Purportedly, Solar can be a Nebula EK disguised under a new name. At the time of writing this report (in June 2017) the topic on the sale was active and the seller was not banned.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Builders of malicious documents exploiting the CVE-2017-0199 vulnerability in Microsoft products	Global	CP-1553

In April 2017, a lot of services selling builders of malicious documents, exploiting the CVE-2017-0199 vulnerability in Microsoft products appeared on underground platforms. The following Windows versions are vulnerable: Windows Vista, 7, 8, 10 - x86/x64, Windows Server 2008, 2010 - x86/x64 and MS Office 2007, 2010, 2013, 2016 - x86/x64. Also, this exploit was added to the MWI exploit pack (MICROSOFT WORD INTRUDER, a developer named Objekt) exploit, actively employed by hackers for targeted attacks.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
1day exploit for the CVE-2017-0261 vulnerability in MS Word	Global	CP-1573

On May 29, 2017, an announcement about the sale of a 1day exploit for the CVE-2017-0261 vulnerability in MS Word with source codes was published on an underground forum. The price is 20,000 USD. The CVE-2017-0261 vulnerability will allow executing remote code in Microsoft Office 2010 SP2, Office 2013 SP1, Office 2016. It affects the 32- and 64-bit versions of Windows 7 to 10. The seller says that this exploit is an alternative to CVE 2017-0199, which only operates on 2013-2016 versions of MS Office and can be detected by antivirus solutions.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Exploit to bypass UAC in Windows	Global	CP-1572

On an underground forum, researchers detected an exploit to bypass Windows User Account Control (UAC). It is designed to provide administrative privileges to the process. According to the seller, the exploit is written in C++, has a small size (less than 100 KB), and runs on 32- and 64-bit versions of Windows 7, 8, 8.1, 10.

At the end of Q2 2017, this information was not confirmed. The seller is a recently registered user without reputation. One of the users of the forum says that he bought this exploit and is actively using it.

APT name	Regions attacked	Operation start
TA549	Central Asian countries, Russia, Belarus, Mongolia	April 20, 2017

On April 20, 2017 security specialists observed a targeted campaign focused on financial analysts working at top global financial firms operating in Russia and neighboring countries. This attacker dubbed TA459 is believed to operate out of China. In their phishing campaign, hackers used a Microsoft Word document called 0721.doc, which exploited CVE-2017-0199 to deploy the ZeroT Trojan, which in turn downloaded the PlugX Remote Access Trojan (RAT). Also, a diverse malware arsenal of this group includes NetTravaler malware.

Banking threats for PC and Android

Malware	Regions attacked	Related notification	Detection
TinyNuke	Global	CP-1539	January 2017

In late March 2017 a criminal named aainz, who is the developer of the TinyNuke banking Trojan (aka NukeBot, Micro Banking Trojan and Nuclear Bot), published the source code on github.com. This malware affects Windows systems (32/64) from XP to 10. The Trojan has the following capabilities: form grabber, web injects, HVNC, bypassing UAC, Windows and IBM Trusteer's firewalls.

Screenshot –TinyNuke control panel

The publication of this source code may lead to the appearance of new modifications of this Trojan with additional functions, provoking an increase in monetary thefts.

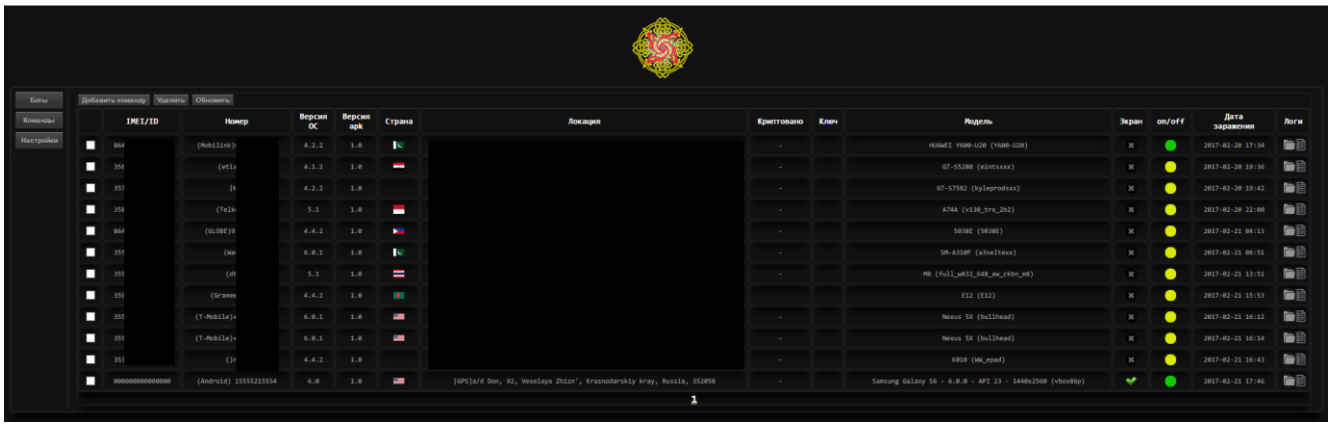
It is also interesting to note that following this a topic appeared on an underground forum, which is a commercial project, in which anyone can invest (the price of the entry is 5 btc, but the team does not exceed 15 members), they will develop TinyNuke 2 based on the published source codes and will be able to use it. The author of this topic is a criminal named BMWstyle77.

Malware	Regions attacked	Related notification	Detection
Rello	Global	CP-1546	January 2017

An Android bot with the functionality of crypto-locker, named Rello, appeared on sale in Q1, and in Q2 it continued to develop actively. Currently, a list of its capabilities is quite extensive:

- does not require administrative privileges
- intercepts SMS on all versions of Android (full interception on versions up to 4.4, after - silent mode is turned on)
- screen locking with a typical text that is customized in the control panel
- executes shell commands
- calls/USSD requests
- Sending SMS
- Self SMS

- getting the list of applications
- getting the list of contacts
- CC grabber (fake Google page that asks for credit card data; it starts only when the victim opens Google Play/Google Play Music)
- SMS spam (to the contact list)
- obtaining the user's location
- AES-256 encryption



Screenshot – Rello control panel

Malware name	Regions attacked	Related notifications	Detection
Marcher	Global	CG-1497-2	2016
Alien-bot		CG-1497-3	

A criminal group dubbed busy897987989879 that has been known to the public since 2016 is currently active. This group uses an Android banking Trojan called Marcher and its version Alien bot. Marcher is distributed through malicious SMS mailouts, primarily targeting banks in Australia and the US.

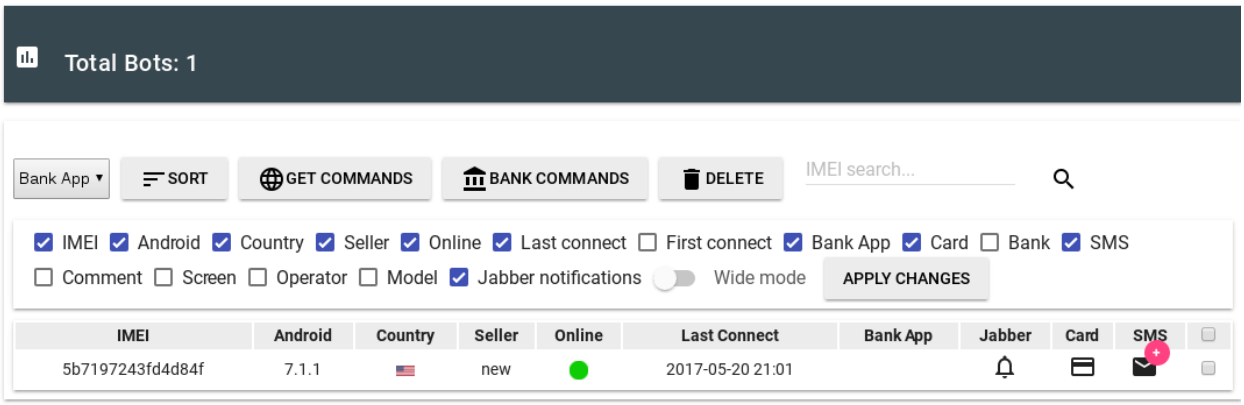
Alien bot contains injects for banks in Austria, France, Germany, Turkey, Australia, and Poland. However, according to analysis of attacked devices, the majority of them are located in the Asia region.

Malware name	Regions attacked	Related notifications	Detection
Loki	Global	CP-1566	2017

This new Android banking bot has the functionality to intercept, delete, and send SMS messages, as well as to detect victim's banking applications and display fake pages of certain banking applications. The package contains 90 fake pages of banks in various countries except for Russia.

According to its seller, earlier the program was sold only via private messages, and only now it has come to the market. Old clients continue using it.

A famous user of underground forums named maza-in tested Loki and published a review. He says that the program performs all announced functions and operates consistently on a real device, even if it has been in sleep mode for a few hours.



Screenshot – Loki Android bot control panel

Malware name	Regions attacked	Related notifications
Gaudox HTTP Loader	Global	CP-1555

Group-IB specialists detected an announcement about the sale of source codes for the malicious program Gaudox HTTP Loader. This malware is written in C, runs on Windows versions from XP to 10 (x86/x64), has the functionality to bypass UAC for Windows 7 and higher (x86/x64), supports multithreading, downloads and executes EXE (32/64-bit), DLL (32/64-bit), JScript, VBScript, Powershell files. This malicious software increases the risk of infection with additional malware, further data breaches, and targeted attacks.

Screenshot – Gaudox HTTP Loader control panel

Malware name	Regions attacked	Related notifications	Detection
Red Alert	All countries except CIS	CP-1575	2017

On May 29, 2017 an announcement about a new Android bot Red Alert offered for lease was published on an underground forum. Currently, its basic functionality includes intercepting and sending SMS messages, launching an apk file, and demonstrating fake pages. The cost of rent at the moment is relatively low - 500 US

dollars per month. The package includes ready-to-use fake pages for banks in Poland, Germany, France, Italy, Turkey, and grabbers of data disguised as WhatsApp, Viber, Instagram, and Skype.

We also reported about the appearance of an Android bot dubbed UfoBot. Later, the topic was closed due to the fact that the seller appeared to be a cheater, who was selling a non-existent product (notification CP-1579).

Also, in Q2 researchers observed activity of the following banking Trojans:

Name	Detection	Countries attacked
TrickBot	2016	Germany Canada Australia

Examples of attacked banks:

Australia and New Zealand Banking Group
Deutsche Postbank AG
Bank of Montreal
Citibank
Toronto-Dominion Bank (TD BANK)
Bank of Queensland (BOQ)
Greater Bank
National Australia Bank
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Bankwest
Suncorp Bank
Commonwealth Bank of Australia
NETELLER
Westpac

Name	Detection	Countries attacked
Qadars	2013	Canada USA Italy Germany UK

Examples of attacked banks:

Bank of Montreal
Fifth Third Bank (53 bank)
Skrill
Citibank
Caisses Desjardins
Barclays
Bank of America
The National Bank of Canada
Bwin Interactive Entertainment AG
Chase Bank

Canadian Imperial Bank of Commerce (CIBC)
Toronto-Dominion Bank (TD BANK)
American Express
Halifax
Lloyds Bank
Wells Fargo
Scotiabank
Tescobank
Ingdirect (it)
Commerzbank

Name	Detection	Countries attacked
Gootkit	2014	Canada France Switzerland

Examples of attacked banks:

Bank of Montreal
Caisses Desjardins
The National Bank of Canada
Canadian Imperial Bank of Commerce (CIBC)
Kantonalbank (Switzerland)
LCL (France)

Name	Detection	Countries attacked
Qbot	2009	USA Netherlands Canada

Specialists detected a spike in activity of the QBot banking Trojan (aka PinkSlip). It locked thousands of Active Directory users out of their corporate domains. Discovered in 2009, the malware has significantly evolved over time. The Trojan features a modular design, is multithreaded, and includes components designed to steal keystrokes, online banking credentials, digital certificates, authentication tokens, and cookies, implement a backdoor, and create a SOCKS proxy. In the new version developers also added the functionality to bypass AV solutions. The program is primarily used to target businesses, stealing money from their bank accounts. QBot is able to spread like a worm by self-replicating through shared drives and removable media. The current campaigns appear focused on U.S. financial organizations.

Examples of attacked banks:

ABN AMRO Bank
Citibank
Huntington Bancshares, Inc.
Toronto-Dominion Bank (TD BANK)
Bank of America
First Citizens Bank
Citizens Financial Group

First Tennessee Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank
Fifth Third Bank (53 bank)
FirstMerit Bank
JPMorgan Chase
KeyBank
Scotiabank
Capital One
Wells Fargo

Name	Detection	Countries attacked
Tinba	2012	USA Australia Canada UK Germany

During the reporting period we detected high activity of the Tinba malware. Below are only some of their targets:

Members Equity Bank Limited
Royal Bank of Canada
ABN AMRO Bank
ABS Building Society
Caisses Desjardins
IMB Bank
JPMorgan Chase
Skrill
Westpac
Citibank
KeyBank
Advanta Bank Corp
Akamai Technologies
AlertPay
Alterna Savings and Credit Union Ltd.
Amazon.com, Inc.
TD Ameritrade
Australia and New Zealand Banking Group
ASB Bank
ATB Financial
Auswide Bank
Maleny Credit Union
ABANCA Corporación Bancaria, S.A.
BB&T Bank
Deutschen Bank
Sparda-Bank
Bank of America
Bank of Melbourne
Toronto-Dominion Bank (TD BANK)
Beaubear Credit Union
Bendigo and Adelaide Bank
Laurentian Bank of Canada
Banco Mare Nostrum, S.A.
Bank of Montreal
Bank of New Zealand (BNZ)
Huntington Bancshares, Inc.
The National Bank of Canada
Bwin Interactive Entertainment AG
Caisse populaire de Clare
CashU
First Citizens Bank
Community Credit Union
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Citizens Financial Group
Charles Schwab Corporation
NETELLER
Comdirect Bank AG
Commonwealth Bank of Australia
Commerzbank
Conexus Credit Union
Wells Fargo
Copperfin Credit Union
First Tennessee Bank

Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank
Australian Military Bank
Customs Bank
Police Bank
Entegra Credit Union
Fifth Third Bank (53 bank)
First Calgary Financial
FirstMerit Bank
G&F Financial Group
American Express
Greater Bank
Libro Credit Union
Grow Financial
Pennsylvania State Employees Credit Union (PSECU)
TSB Bank
Hamilton Sound Credit Union
BankVic
Bank of Queensland (BOQ)
Kiwibank
National Australia Bank
Teachers Mutual Bank
B&E Personal Banking
Bankstown City Unity Bank
Bananacoast Community Credit Union (BCU)
Hume Bank
Bank of South Australia (BankSA)
Cairns Penny Refreshing Banking
St.George Bank
Bankwest
Implicity Financial
Adelaide Bank
First Option Credit Union
Suncorp Bank
Regions Financial Corporation
Macquarie Bank
ME Bank
Scotiabank
Capital One

Name	Detection	Countries
Zeus	2007	USA Australia UK Spain Italy Turkey Germany

Examples of attacked banks:

Fifth Third Bank (53 bank)
Australia and New Zealand Banking Group
Halifax
HSBC Bank
Wells Fargo
Usbank
Citibank (de)
Unicaja
Popso
Bancopastor
Lloydsbank
Isbank
Santander
Caixa

Name	Detection	Countries attacked
ZeusVM (KINS)	2013	UK Canada

		Australia

Examples of attacked banks:

Royal Bank of Canada
Caisses Desjardins
American Express
Australia and New Zealand Banking Group
Barclays
Bendigo and Adelaide Bank
Bank of Montreal
The National Bank of Canada
Canadian Imperial Bank of Commerce (CIBC)
Citibank
Greater Bank
Halifax
BankVic
Bank of Queensland (BOQ)
National Australia Bank
B&E Personal Banking
Bank of South Australia (BankSA)
St.George Bank
Bankwest
Adelaide Bank
Suncorp Bank
Commonwealth Bank of Australia
Lloyds Bank
Westpac
Scotiabank

Name	Detection	Countries attacked
Atmos	2015	USA Australia Germany Spain Netherlands UK

Examples of attacked banks:

Fifth Third Bank (53 bank)
ATB Financial
Australia and New Zealand Banking Group
Deutschen Bank
Bank of Montreal
Canadian Imperial Bank of Commerce (CIBC)
Halifax
HSBC Bank
Comdirect Bank AG
Wells Fargo

Attacks on ATM and POS terminals

- Security specialists at Trend Micro discovered a new version of the POS Trojan dubbed RawPOS, which while focused on stealing bank card data, is also able to steal the driver's license information from the user. With this new behaviour, the threat actor has vast information about the victim – specifically: full name, date of birth, and full address.
- Kaspersky Lab researchers have analyzed a new malicious program designed to steal money from ATMs dubbed ATMitch. With this malware, criminals managed to steal 800,000 USD from Russian ATMs in 2016. Usually criminals start by getting information on the number of banknotes in the ATM's cassettes. After that, a criminal can send a command to dispense any number of banknotes from any cassette. After withdrawing money in the unique way, criminals only need to grab the money and go. Once an ATM is robbed, the malware deletes its traces, which significantly complicates investigative activities.
- Europol arrested 27 members of the Black Box group accused of being involved in a series of successful black box attacks against ATMs across Europe, which resulted in more than €45 million in losses.
- Incidents using Blackbox devices for thefts from ATMs were identified in Switzerland, Spain, and Ukraine.
- 31 members of a criminal group that had been involved in thefts using skimmers in Spain and Bulgaria from 2014 to 2017 were detained.

Data leakage

- Experts at Appthority, a mobile security firm, published a report that showed 43 terabytes of data from enterprise apps left exposed. The information was spread across 21,000 servers and linked to more than 1,000 mobile apps. Specialists researched in detail 39 applications with big data leaks, which exposed an estimated 280 million records (163 GB). These records were accessible as a result of weakly secured backends that did not require authentication of any kind to access the data. The vulnerability was called HospitalGown. Researchers analyzed the network traffic of over a million enterprise mobile iOS and Android apps and led to the discovery of over 21,000 open Elasticsearch servers with unprotected data connected to apps frequently found on enterprise devices. Multiple affected apps leaked some form of personally identifiable information, including passwords, location, travel and payment details, corporate profile data (including employees' VPN PINs, emails, phone numbers), and retail customer data In multiple cases, data has already been accessed by unauthorized individuals and ransomed. Even apps that have been removed from devices and the app stores still pose an exposure risk due to the sensitive data that remains stored on unsecured servers.

  The InterContinental Hotels Group (IGH), a multinational hotel chain that owns such prestigious brands as Holiday Inn and Crowne Plaza, confirmed a credit card data breach occurred at select hotels between September and December 2016.

  In February IHG reported that POS devices in restaurants and bars at 12 of its locations had been infected with malware.

  A data breach involving InterContinental Hotels Group, has proved to be significantly larger than earlier reported. 1,174 franchise hotels in the US are known to have had malware accessing payment data from cards used at the front desks.

  The hackers infected the hotels' servers, which processed payment card data, with malware. The program searched for track data read from the magnetic strip of payment cards, including data such as cardholders' name, card number, expiration date, and internal verification code.
- For the second time in three years, hackers have installed malware on POS systems at US discount chain Kmart and stolen customer credit card data. Kmart store payment data systems were infected with an unknown program that was undetectable by current anti-virus systems. Once aware of the new malicious code, the company immediately took steps to remove it. Based on the forensic investigation, no personal identifying information was obtained by the criminals. However, security specialists believe certain credit card numbers have been compromised. The company is not commenting on how many of Kmart's 735 locations nationwide may have been impacted or how long the breach is believed to have persisted.

Threats to the Financial Sector in Russia and the CIS

GROUP-IB

GLOBAL CYBER SECURITY COMPANY

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks from the Cobalt hacker group	Russia, Kazakhstan, Ukraine	CP-1438-17 – CP-1438-25	June 2016

In Q2 2017 researchers detected numerous spear-phishing campaigns from the Cobalt group, primarily targeting banks and payment systems in Russia, as well as financial institutions in Kazakhstan and Ukraine. In addition they sent emails in English, targeting companies outside the CIS. Mailouts were performed acting as the CyberPlat payment system, the mobile operators Beeline, MTS, Megafon, as well as Sberbank, PCI DSS, the Moneta.ru instant payment system, FinCERT, and Qiwi payment system.

Also, cybercriminals sent malicious emails from compromised corporate servers, for example, they leveraged a server belonging to the cash collection service of the Kazakh bank Halyk Bank.

Emails contained documents with exploits for CVE-2017-0199 and CVE-2016-7193 vulnerabilities.

Some of the attacks resulted in successful thefts.

Researchers also revealed that through one of the attacks criminals successfully obtained access to the bank's corporate network and infected machines with PetrWrap ransomware.

In May, security specialists detected that the Cobalt Group was testing a new reconnaissance Trojan on the territory of Russia. This new tool may complicate tracking the criminal group, as well as increase the effectiveness of their future attacks. It is also interesting to notice that in the recent attacks criminals checked the victim's computer for Dr.Web Anti-virus software installed. In the event they detected the solution, the Cobalt Strike program was not downloaded to the target machine.

APT name	Regions attacked	Related notifications	Operation start
MoneyTaker (Fin7)	USA, Russia, Hong Kong	CP-1559	2016

The MoneyTaker group (aka Fin7) is a Russian-speaking technically sophisticated criminal group that conducts targeted attacks on financial institutions throughout the world. Their main goal is to gain access to critical bank systems such as SWIFT, ATMs, card processing systems, banking software, POS software, as well as to steal confidential documents to commit fraud.

Moneytaker is closely linked to Anunak (Carbanak). One of their distinguishing features is that they usually load their tools into the memory of an infected machine, that's why researchers call their attacks "file-less". With this attack method, it is extremely difficult to detect the infection using antivirus and IDS solutions, because the operation of malicious programs and data transfer are hidden.

Their peak activity was observed in late 2016, when they actively attacked financial companies in Russia, Hong Kong, and the United States. At the time, a number of security companies began to investigate activity of group, which they dubbed Fin7. In Russia, these hackers performed a successful attack via the ARM CBR (Automated Work Station Client of the Russian Central Bank).

In Q2 2017, Group-IB specialists managed to discover the critical infrastructure of Fin7 and identify thirteen successful targeted attacks, some of which may still remain undetected by the victims. In these attacks, criminals compromised corporate networks and, in some cases, accessed confidential documents related to SWIFT, card processing systems, ATM control software and other highly sensitive information about VIP clients of banks.

Hackers infiltrate corporate networks using spear-phishing emails with malicious files acting as financial organizations or leverage compromised networks of financial institutions' Internet providers.

APT name	Regions attacked	Related notifications	Opera
Telebot	Ukraine	CP-1540	2016

Group-IB specialists uncovered details of the attack on Ukrainian financial institutions using the TELEBOT backdoor, which was controlled via Telegram Bot API. The malware was distributed through phishing emails with Microsoft Excel documents containing malicious macros. In January-February 2017, hackers managed to compromise the network of a large Ukrainian systems integrator. The attackers leveraged the infected network to access systems of at least four Ukrainian banks and download a Trojan that is similar to Telebot, but written in Rust. Purportedly, the malware was used to conduct cyber-sabotage attacks on Ukrainian banks. This hypothesis is confirmed by the fact that in the final stage of its attacks the group used a ransomware component to encrypt files on the victim's device. This activity is similar to the attacks on Ukrainian energy networks performed by a state-sponsored group BlackEnergy. Through analysis of emails, experts discovered similar macro codes to those used in the attacks on Ukrainian energy networks performed by a state-sponsored group BlackEnergy in December 2015.

ESET security researchers identified that the Telebot group had used another ransomware family Win32/Filecoder.AESNI.C, which was spread using Ukrainian accounting software called M.E.Doc. The Petya ransomware was distributed using the same initial infection vector. This may mean that the Petya outbreak was initiated by the Telebot group.

Banking Trojans for PC and Android

Malware name	Regions attacked	Detection	Notification
Agent.BID	Russia	2015	CP-1565

A new wave of attacks using the Agent.BID banking Trojan for Android was detected. The Trojan is distributed via SMS. Once installed on the victim's device, the application displays an icon with the "Sberbank" logo. The threat is designed to steal online banking credentials and bank card data. Also, the malware is able intercept and send SMS messages. It's worth reiterating that in 2016 this Trojan was actively used by intruders, however in November its activity significantly decreased.

Malware name	Regions attacked	Detection	Notification
Lipton	Russia	2017	CP-1562

Group-IB specialists analyzed a sample of a new malicious program for Android, the Lipton banking Trojan, which is believed to be a new breed of Limebot malware designed to steal money from Russian banks. The Trojan has the following functionality: gain administrative privileges on the device, intercepts SMS messages, and displays fake pages. This Trojan has already been tracked in successful attacks.

Malware name	Regions attacked	Detection	Notification
TarkBot	Russia	2014	CP-1568

TarkBot is ransomware for Android-based devices, which has been active since 2014. In May 2017, a new spike in TarkBot activity was observed. The malicious application is spread via SMS messages sent from infected devices, targeting Russian users. It blocks the smartphone operation and demands to pay a ransom, or displays pop-up messages requesting to enter Sberbank bank card details. The application also has the functionality to read the victim's contact list, capture incoming and outgoing SMS messages, and send SMS messages.

Malware name	Regions attacked	Detection	Notification
Asacub	Russia	2014	CP-1580

In late June, researchers tracked a new wave of malicious SMS messages with a link to the Asacub banking Trojan. Once the victim's device is infected, the Trojan starts sending messages to the entire contact list, and sends SMS to short number 900 in order to find out the balance of the victim's bank card (in the event the victim is a client of Sberbank).

Currently, Asacub is the most active Android Trojan in Russia. It has the following functionality: sends a list of installed applications, the browsing history and contact list to the C&C server, sends SMS messages to the specified number, downloads the history of messages to the C&C server, displays phishing pages over legitimate applications, forwards calls to the specified number, sends USSD requests, downloads files from a specified link and installs them.

Threat name	Detection	Regions attacked
Buhtrap	2014	Russia

Buhtrap malware is designed to collect authentication data, search for specific online banking apps and processes as well as to replace payment details. Currently, the group is targeting funds.

Threat name	Detection	Regions attacked
Ranbyus	2012	Russia

Ranbyus is a banking Trojan targeting online banking and payment systems. Its specific feature is absence of web injects that are usually employed in such attacks. Instead the malware conducts attacks on specific banking software. Ranbyus changes Java code in popular applications, such as the iBank2 online banking system, without modifying JVM (Java virtual machine).

Threat name	Detection	Regions attacked
Agent.sx	2015	Russia

Criminals use this banking bot, which has capabilities to send and intercept SMS messages, to perform unauthorized money transfers through SMS banking. Developers have added an auto-reply function to the malware control panel, which enables attackers to send messages with transfer confirmation automatically. The program also has the functionality to parse SMS messages in order to obtain victim's card balance. This parser can be customized for any bank. The Trojan also has capabilities to collect bank card data using a Google play phishing dialog.

Threat name	Detection	Regions attacked
Gugi/Limebot	August 2016	Russia

The Trojan is designed to overlay applications with phishing windows in order to steal mobile banking data and credit card data. In addition, it is able to steal SMS and contact lists, perform USSD requests and send SMS on command from the C&C server. In Q2 2017, Gugi/Limebot attacked the following banks: VTB24, Raiffeisen Bank, Tinkoff Bank, Alfa Bank, Sberbank. The Trojan spreads via SMS spamming and uses fake windows to capture data.

Attacks on ATMs

- Despite the fact that Cobalt has turned their efforts to stealing from card processing systems, the group is expected to continue attacking ATMs.
- Attacks on ATMs were purportedly performed by the MoneyTaker group.
- Criminals used ATMitch malware to steal money from ATMs of Russian banks; criminals have not been identified.

Data leakage

During the reporting period Group-IB specialists detected 13 incidents of providing/selling/searching for confidential bank data related to Russian and Ukrainian banks on underground resources. Insiders in banks are believed to be involved in these incidents. Criminals offered the following information:

They include:

- Sales of clients' databases;
- Sales of information about bank accounts;
- A service of unblocking frozen accounts.

Threats for the Governments

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT

APT name	Regions attacked	Operation start
APT10 (aka Red Apollo, CVNX, Stone Panda, menuPass Team)	Canada, USA, Norway, Finland, France, Great Britain, Sweden, Switzerland, Brazil, South Africa, India, Thailand, South Korea, Japan, Australia	2016

In April 2017, security researchers reported details of a Chinese group known as APT10, involved in cyber espionage. In 2016-2017 the group used a set of backdoors (HAYMAKER, BUGJUICE, SNUGRIDE) and an open source RAT. A list of their victims includes MSP (managed service providers) companies in the UK, USA, Japan, Canada, Brazil, France, Switzerland, Norway, Finland, Sweden, South Africa, India, Thailand, South Korea and Australia.

APT name	Regions attacked	Operation start
Lazarus (aka Hidden Cobra)	Global	2013

Group-IB specialists performed a large-scale investigation on the Lazarus hacker group and published the findings in its report *Lazarus Arisen* (https://www.group-ib.com/blog/lazarus). The report outlines in detail this group's attack methodology for financial institutions, the malware employed and review of their targets.

Through investigation of attacks on banks, Group-IB specialists have proved that there is a strong connection between Lazarus and North Korea, while the analysis of IP addresses enabled them to locate the attackers, up to the quarter. For several years (in 2013, 2016 and 2017), the Lazarus cyberattacks were ultimately controlled from the same place – the Potonggang district of Pyongyang.

Group-IB team detected and thoroughly analyzed multiple layers of C&C infrastructure used by Lazarus. To control infected machines the criminals used compromised servers throughout the world. Group-IB specialists discovered 74 servers where hackers installed their remote access tools, as well as 30 servers used as proxy servers for bots as well as utilised to conceal the real server used to control malware.

In some cases, they also used corporate web servers that were part of the attacked infrastructure. This means that infected machines will connect to the corporate web server acting as proxy, rather than to external C&C servers.

The attackers achieved anonymity and control over the attacked infrastructure by employing a legitimate VPN client - SoftEther VPN, service supported by University of Tsukuba, Japan.

Lazarus also employs a malware variant known as DeltaCharlie, a distributed denial-of-service (DDoS) bot, to infect machines and include them into their botnet. The US Federal Bureau of Investigation (FBI) and the Department of Homeland Security (DHS) identified several IP addresses of systems infected or someway linked to DeltaCharlie bots.

APT name	Regions attacked	Operation start
Unknown	India	January 2017

In May 2017, an Indian analytical center named "Institute for Defence Studies and Analyses" was attacked. Purportedly, this attack was conducted by the same group that performed attacks on government organizations in India in early 2017. As part of the operation, the group sent phishing emails with a malicious attachment: a Microsoft Office Excel document containing a macro that, when enabled, creates a file with a random name and writes an executable file in decimal format into it, which in turn copies itself to the %AppData%\SQLite directory

under the name “SQLite.exe”. Once this file is executed, a request is made to the C&C server to receive commands.

APT name	Regions attacked	Operation start
APT32, OceanLotus	Europe, Vietnam, USA, Philippines, UK, Germany, China	2014

In May 2017, cybersecurity companies reported the activities of the APT32 hacker group that are aligned to the interests of the Vietnamese government. The group has been attacking private sector companies across multiple industries, such as network security, banking, consumer goods, and media since 2014. As part of the attacks, the group sends phishing emails with malicious attachments, using social engineering to prompt the victim to open the document and run macros.

APT name	Regions attacked	Operation start
APT3	USA, UK, Hong Kong	2010

The APT3 group is related to the company "Guangzhou Boyu Information Technology Company" and to the Chinese Ministry of State Security. On April 26, 2017, a group called "intrusiontruth" published information about the hacking group dubbed APT3, also known as Gothic Panda, Buckeye, UPS Team. In a subsequent publication on May 9, 2017, the "intrusiontruth" group attributed APT3 to Boyusec, a Chinese information security company, which is a contractor of the Chinese Ministry of State Security.

APT name	Regions attacked	Operation start
APT19		May 2017

In May and June 2017, security companies observed a phishing campaign targeting at least seven global law and investment firms. In May the group sent phishing emails with RTF attachments that exploited the CVE-2017-0199 vulnerability in Microsoft Windows. Following this, the hackers switched to using macro-enabled Microsoft Excel (XLSM) documents.

APT name	Regions attacked	Operation start
PLATINUM	South and Southeast Asia	April 2016

In July 2017, security specialists reported an evolution of a file-transfer tool used by the Platinum group since April 2016. One of its versions uses the Intel® Active Management Technology (AMT) Serial-over-LAN (SOL) channel for communication.

Hacktivism

In Q2 2017, hacktivists conducted over 3,800 attacks on more than 4,900 unique online resources. Over 3,100 attacks detected were "page replacement" (Defacement), 500 attacks were DDoS attacks (Denial of Service) and more than 200 incidents of data leakage were detected. In these attacks hacktivists targeted government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Mexico, Brazil, Turkey, Sri Lanka, Venezuela, USA, Peru, Italy, Laos, Nepal, Pakistan.

The table below contains information on the major hacktivists' operations conducted in Q2 2017.

Operation name	**Regions attacked**	**Operation start**	**Types of attacks during the operation**
OpIslam	Europe, North America, South America, North Africa, Eastern Africa, Western Asia, South Asia, East Asia	13.03.2016	DDoS, Deface, Data leakage
	This campaign was launched by the Anonymous group. The hacktivists say that this operation does not aim at "converting everyone to Islam". Instead they fight against resources spreading false and negative information about Islam in attempts to "show the world that Muslims are not terrorist, that Islam does not advertise violence, and that the real message of Islam is peace."		
OpSeaWorld, OpWorldAnimal, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Originally they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. Currently, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, and government organizations in Texas, the USA.		
OpIsrael	Western Asia	07.04.2013	DDoS, Deface, Data leakage
	OpIsrael is an annual operation against Israeli websites and online resources. During the operation hacktivist groups attack government, educational, banking and non-governmental resources and media portals. The operation starts on April 7th every year.		
OpISIS	ISIS, Middle East, Islamic organizations worldwide	11.08.2014	DDoS
	During the OpISIS operation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources.		
OpVenezuela	South America	20.01.2011	DDoS, Deface
	This operation was initiated by the Anonymous group following violent repression against anti-government protesters and instances of internet censorship in Venezuela.		
OpTurkey	Turkey	10.09.2014	DDoS, Deface

	In Q2 2017 hacktivists continued attacking Turkish websites. In addition to government resources, they started hacking Turkish DNS servers. This operation was initiated by the Anonymous group. This campaign was provoked by the deaths of 10 construction employees. The workers were killed when their elevator crashed. Anonymous expressed their outrage at what they saw as Turkey's lack of both funds & safety measures regarding construction sites and workplaces.		
OpSouthAfrica	South Africa	08.05.2015	DDoS
	This operation was initiated by the Anonymous group. According to its organizers, their goal is to attract public attention to President Jacob Zuma's rape accusations.		
OpSingleGateway	Thailand	22.10.2015	DDoS, Deface, Data leakage
	This Anonymous campaign targets Thailand government websites. The operation was originally launched when the Thai government started working on a bill that would force the country's entire Internet traffic through one single gateway. The centralized gateway would give the government the ability to control, intercept and arrest any person not complying with new Internet laws.		

Deface attacks: Additional Statistics

Group-IB specialists have summarized statistics of hacked websites (deface attacks), which is presented in charts below.

Chart 1 provides the breakdown of attacked resources by web servers used.

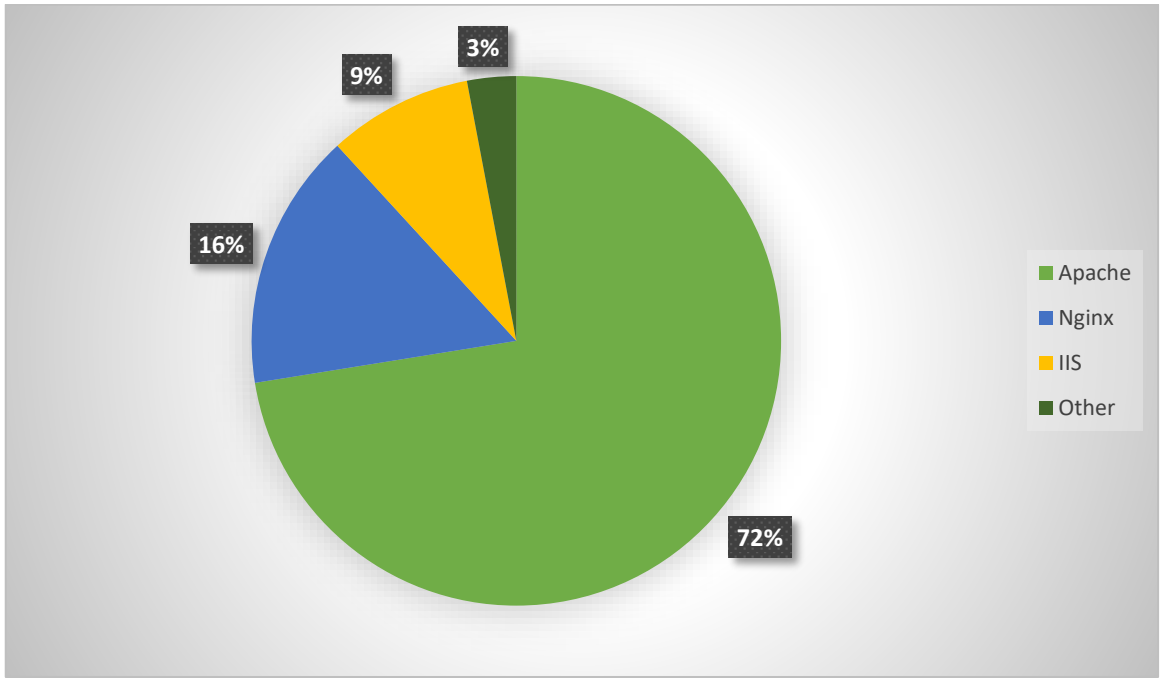


Chart 1 – Attacked resource ratio by web server

Chart 2 provides the breakdown of attacked resources deployed using IIS web servers. As seen from the chart, the most popular versions are 6.0, 7.5 and 8.5. This can be explained by the fact that each version is released as a component of a Windows operating system. For example, version 6.0 was included in Windows Server 2003,

version 7.5 was part of Windows 7 and Windows Server 2008, and version 8.5 was included in Windows 8.1 and Windows Server 2012 R2. These statistics demonstrate that many users are slow to update operating systems on their devices. However, the WannaCry and Petya.C ransomware attacks made it clear that it is critical to keep up with updates and patches in a timely manner to prevent hackers from being successful.

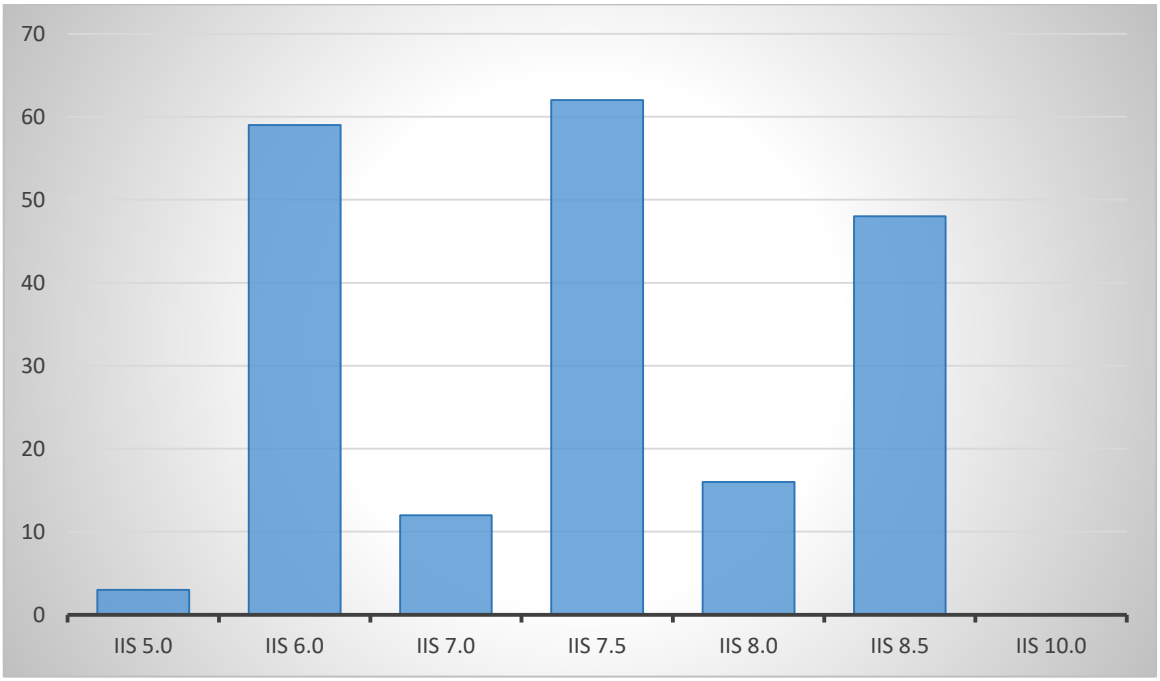


Chart 2 – Attacked resource ratio by IIS version installed

Over a third of all attacked resources were created based on content management systems (CMS). Chart 3 provides the breakdown of attacked resources by CMS used. The percentage of CMS WordPress decreased by more than one and a half times compared to the previous quarter. This can be explained by the decline in attacks on this system compared to the spike in activity in Q1 – in early February researchers discovered a serious CMS WordPress, which allowed attackers to covertly raise their privileges using REST API. Back then hackers reportedly attacked around 2 million resources based on WordPress.

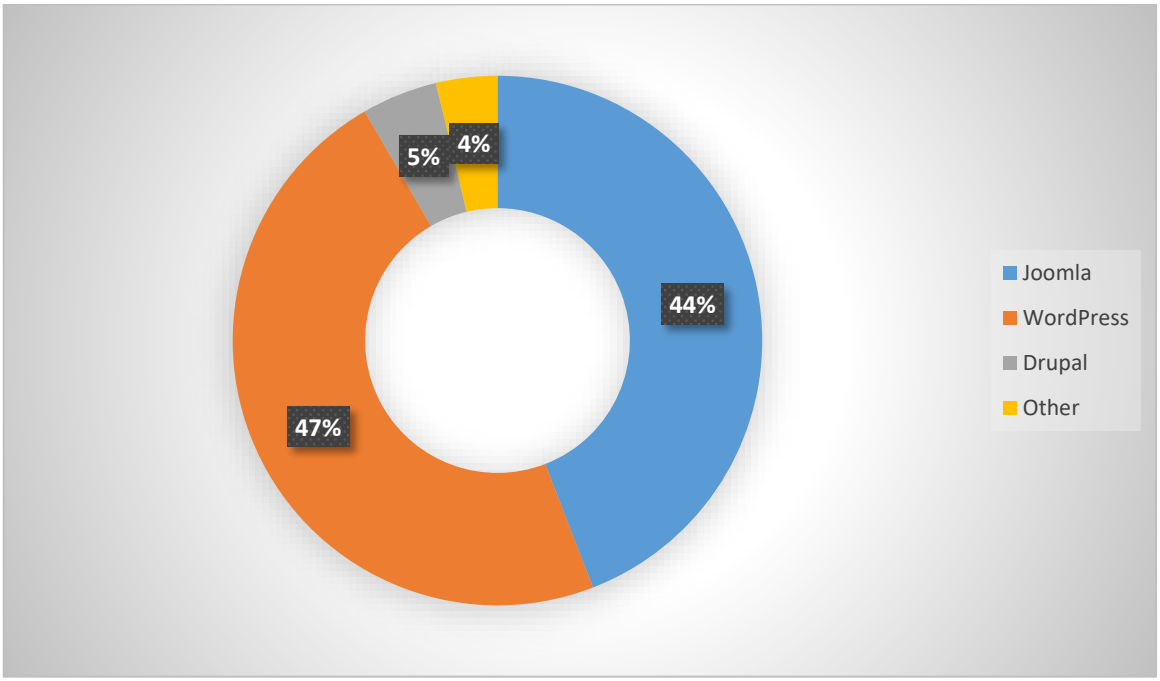


Chart 3 – Breakdown of attacked resources by CMS

Data leakage

- In May and June WikiLeaks released documents providing insights into how the CIA was secretly spying on their targets.
  On May 19 the resource published new documents detailing the Athena project, showing that the CIA had the ability to hack Windows. Other CIA tools leaked during the reporting period are AfterMidnight, Assasin, and Archimedes.
  In early June WikiLeaks published a new portion of documents on an alleged CIA's "Pandemic" project, allowing the spy agency to give file servers the capability to infect machines which access them remotely. According to WikiLeaks, Pandemic is a persistent implant designed to replace files in Microsoft Windows machines on-the-fly with a Trojan, turning a Windows file server into a malware distribution point on the local network.
- The Shadow Brokers group published archives of the NSA espionage tools that may be used by government-backed groups. They also launched a subscription-based monthly dump of new tools from the NSA and CIA leaks. There are ETERNALBLUE, ESTEEMAUDIT, Eternalchampion, Eternalromance, Eternalsynergy, Doublepulsar, Architouch, SMBtouch and others among them.
- The personal information of more than 198 million American voters were available publicly on the Amazon S3 server. The database contains information about the name, date of birth, home address, phone numbers, and party affiliation of each voter. Data was collected during the preparation for the presidential elections by the analytical company Deep Root Analytics (DRA) and two other contractors for the Republican Party.